

Security+ 4.8 · Digital Forensics

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.8 — Digital Forensics (9:54)** ·

[Vídeo no YouTube ↗](#)

Resumo da Aula: Forense: data collection (VOLÁTIL primeiro — RAM→cache→disco→backup); legal hold (preserva evidência — notifica o jurídico); chain of custody (quem tocou/ quando — sem isso a evidência não vale em tribunal).

Highlights que a prova cobra

- Ordem de volatilidade: RAM primeiro (perde ao desligar)
- Chain of custody: o registro formal de cada ação com a evidência

Dicas de prova & Cenários Típicos

- 'documenting who handled the evidence'=chain of custody

Cenário clássico de exame: 'registro que mapeia a evidência do incidente até o tribunal'=chain of custody.

 **Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e**

Armadilhas da Seção 4.8)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Digital Forensics) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Monitoramento de Segurança (SIEM, SOAR, EDR/XDR):**
 - **SIEM:** centraliza, normaliza e correlaciona eventos de logs em tempo real para disparar alertas de segurança.
 - **SOAR:** automatiza respostas a incidentes através de playbooks coordenados, reduzindo o tempo de reação humano.
 - **EDR/XDR:** detecção e resposta a anomalias no endpoint (EDR) estendida a e-mail, nuvem e identidades (XDR).
- **Fases da Resposta a Incidentes (NIST SP 800-61 / PICERL):**
 1. **Preparação:** políticas, ferramentas, treinamentos.
 2. **Identificação/Detecção:** triagem de alertas e confirmação do incidente.
 3. **Contenção:** isolamento do sistema afetado para impedir propagação (sem destruir provas).
 4. **Erradicação:** remoção de malwares, fechamento de brechas e contas comprometidas.
 5. **Recuperação:** restauração segura dos serviços a partir de backups limpos e validação de produção.
 6. **Lições Aprendidas:** reunião pós-incidente e melhorias nos playbooks.
- **Forense Digital e Ordem de Volatilidade (RFC 3227):** Durante a coleta de evidências forenses, os artefatos mais voláteis (que somem ao desligar) devem ser capturados primeiro:
 1. Registradores da CPU e memória Cache.
 2. Memória RAM (volátil: contém senhas em claro, chaves criptográficas em uso e conexões ativas).
 3. Estado das conexões de rede e processos em execução.
 4. Sistema de arquivos e discos rígidos (HD/SSD).
 5. Mídias ópticas e backups externos arquivados.

⚠ **Armadilhas e Pegadinhas Clássicas da Banca:**

- NUNCA desligue ou reinicie um servidor comprometido antes de realizar o dump forense da memória RAM; reiniciar destrói evidências essenciais de malwares fileless.
- Qualquer manipulação de evidência digital exige cálculo imediato de hash (SHA-256) e registro rigoroso da Cadeia de Custódia (Chain of Custody).

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:

- A)** O HD / disco
- B)** A memória RAM (dados voláteis)
- C)** Os backups em fita
- D)** Os logs impressos

2. Registro que documenta quem tocou uma evidência, quando e por quê (forense):

- A)** Cadeia de custódia
- B)** Ordem de volatilidade
- C)** Retenção de log
- D)** Não-repúdio

3. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Ordem de volatilidade: RAM primeiro (perde ao desligar)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Ordem de volatilidade: RAM primeiro (perde ao desligar)...

4. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Chain of custody: o registro formal de cada ação com a evidência'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Chain of custody: o registro formal de cada ação com a evidência...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'documenting who handled the evidence'=chain of custody'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'documenting who handled the evidence'=chain of custody...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'registro que mapeia a evidência do incidente até o tribunal'=chain of custody'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'registro que mapeia a evidência do incidente até o tribunal'=chain of cust...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Ordem de volatilidade: RAM primeiro (perde ao desligar)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Ordem de volatilidade: RAM primeiro (perde ao desligar)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Chain of custody: o registro formal de cada ação com a evidência'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Chain of custody: o registro formal de cada ação com a evidência...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'documenting who handled the evidence'=chain of custody'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'documenting who handled the evidence'=chain of custody...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Digital Forensics): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'registro que mapeia a evidência do incidente até o tribunal'=chain of custody'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'registro que mapeia a evidência do incidente até o tribunal'=chain of cust...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) B — A memória RAM (dados voláteis).

✓ **Por que está certa:** O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco → depois backups. Captura o volátil antes que evapore.

✗ **Por que as outras estão erradas:**

- *O HD / disco:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Os backups em fita:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Os logs impressos:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) A — Cadeia de custódia.

✓ **Por que está certa:** Cadeia de custódia rastreia a evidência de ponta a ponta — se quebra, a evidência perde validade jurídica.

✗ **Por que as outras estão erradas:**

- *Ordem de volatilidade:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Retenção de log:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Não-repúdio:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) D — Implementar a solução correspondente: Ordem de volatilidade: RAM primeiro (perde ao desligar)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): Ordem de volatilidade: RAM primeiro (perde ao desligar).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) A — Implementar a solução correspondente: Chain of custody: o registro formal de cada ação com a evidência....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): Chain of custody: o registro formal de cada ação com a evidência.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para

detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: 'documenting who handled the evidence'=chain of custody....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): 'documenting who handled the evidence'=chain of custody.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: 'registro que mapeia a evidência do incidente até o tribunal'=chain of cust....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): 'registro que mapeia a evidência do incidente até o tribunal'=chain of custody..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: Ordem de volatilidade: RAM primeiro (perde ao desligar)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): Ordem de volatilidade: RAM primeiro (perde ao desligar).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: Chain of custody: o registro formal de cada ação com a evidência....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): Chain of custody: o registro formal de cada ação com a evidência.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: 'documenting who handled the evidence'=chain of custody....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): 'documenting who handled the evidence'=chain of custody.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: 'registro que mapeia a evidência do incidente até o tribunal'=chain of cust....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Digital Forensics): 'registro que mapeia a evidência do incidente até o tribunal'=chain of custody..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam

ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.